

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

GUIDE-NYDFS-02

NYDFS Readiness Roadmap

A Phase-by-Phase Compliance Roadmap for 23 NYCRR Part 500 Covered Entities  
TSEC Compliance Insights | NYDFS Series

|                 |                                |
|-----------------|--------------------------------|
| Document ID:    | GUIDE-NYDFS-02                 |
| Version:        | 2026 Edition                   |
| Effective Date: | June 2026                      |
| Classification: | CONFIDENTIAL                   |
| Prepared by:    | TSEC Risk & Cyber Advisory LLC |

# 1. Introduction

Achieving and maintaining compliance with 23 NYCRR Part 500 requires a structured program that addresses governance, risk assessment, technology controls, vendor management, incident response, and ongoing certification. This Readiness Roadmap provides a practical, phase-by-phase approach for Covered Entities building or maturing their Part 500 compliance programs.

## 2. Phase 1: Governance Foundation (Weeks 1-4)

### Designate the CISO

Section 500.4 requires a qualified CISO. If you don't have one, designate one now — either a full-time employee, a shared resource from an Affiliate, or a qualified third-party provider with a designated internal oversight contact. Document the designation formally and ensure the CISO has a clear reporting line to the Senior Governing Body.

### Engage the Senior Governing Body

The 2023 amendments require the Senior Governing Body to have cybersecurity oversight capability. Brief the Board or equivalent on their obligations under Part 500, ensure they understand the 72-hour notification requirement and what it means for their involvement, and establish a mechanism for the CISO to escalate material risks to them between annual reports.

### Inventory Your Regulatory Obligations

Confirm which sections of Part 500 apply to your organization, including whether you qualify for any exemptions, and whether you are subject to the enhanced requirements applicable to Class A companies. Review the 2023 amendment compliance deadlines — different sections had staggered implementation timelines.

## 3. Phase 2: Risk Assessment (Weeks 4-8)

Section 500.9 requires a periodic risk assessment that meets specific documented criteria. Your risk assessment must produce written documentation including evaluation and categorization criteria, CIA assessment criteria, and risk acceptance/mitigation requirements. If you have an existing risk assessment, review it against the 500.9 requirements — many organizations find their existing assessments don't fully meet the new criteria.

Use the results of the risk assessment to update your Cybersecurity Policy (Section 500.3), prioritize control implementation in Phase 3, and calibrate your transaction monitoring, penetration testing scope, and third-party assessment priorities.

## 4. Phase 3: Control Implementation (Weeks 6-20)

| Control Area                | Section | Key Implementation Steps                                                                                                                                                                                 |
|-----------------------------|---------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Multi-Factor Authentication | 500.12  | Audit current MFA coverage; identify gaps for remote access, privileged accounts, and third-party app access; implement MFA for all required scenarios; document any CISO-approved compensating controls |
| Encryption                  | 500.15  | Inventory Nonpublic Information; confirm encryption at rest and in transit; document any infeasibility determinations with CISO approval                                                                 |

|                             |        |                                                                                                                                                                            |
|-----------------------------|--------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Access Privilege Management | 500.7  | Implement periodic access reviews; limit privileged accounts; establish quarterly privileged account review cadence; use PAM solution if Class A                           |
| Penetration Testing         | 500.5  | Engage a qualified penetration tester; scope covers internet-facing and critical internal systems containing Nonpublic Information; schedule for at least annual frequency |
| Third Party Security        | 500.11 | Build a vendor inventory; implement tiered due diligence process; update contracts with minimum cybersecurity provisions including breach notification timelines           |
| Incident Response Plan      | 500.16 | Document a written IRP addressing all Section 500.16 elements; include determination process for Notification Events under 500.17; test annually                           |

## 5. Phase 4: Policy Documentation (Weeks 8-14)

Section 500.3 requires a written Cybersecurity Policy approved at least annually addressing 14 specific policy areas. Review your existing policies against the 14 areas specified in 500.3, identify gaps, and document a consolidated Cybersecurity Policy. Obtain Senior Governing Body or Senior Officer written approval and document the approval date.

## 6. Phase 5: Training and Awareness (Ongoing)

Section 500.14 requires personnel training. Ensure your training program covers: how to recognize and report suspicious activity (including phishing); data handling requirements for Nonpublic Information; password and authentication requirements; and how to report a potential Cybersecurity Event. Train all relevant personnel at hire and annually, and track completion.

## 7. Phase 6: Certification Preparation (Annual)

Section 500.17(b) requires annual certification submission. In Q4 of each year, the CISO should conduct a compliance review against all Part 500 sections, document any areas of non-compliance and remediation timelines, and prepare the certification package for Senior Governing Body and CISO review and signature. The certification is filed via the NYDFS online portal between January 1 and April 15 of the following calendar year.

## 8. Part 500 Readiness Checklist

| Section | Readiness Item                                                                      | Status |
|---------|-------------------------------------------------------------------------------------|--------|
| 500.2   | Cybersecurity Program documented and implemented                                    | [ ]    |
| 500.3   | Cybersecurity Policy covers all 14 areas; Senior Governing Body approved            | [ ]    |
| 500.4   | CISO designated; annual written report to Senior Governing Body implemented         | [ ]    |
| 500.5   | Annual penetration testing completed; bi-annual vulnerability assessments completed | [ ]    |
| 500.7   | Access privilege review process implemented; privileged accounts reviewed quarterly | [ ]    |
| 500.9   | Risk Assessment completed with documented criteria; used to inform controls         | [ ]    |

|        |                                                                                                 |     |
|--------|-------------------------------------------------------------------------------------------------|-----|
| 500.11 | Third Party Security Policy implemented; vendor inventory current; contracts updated            | [ ] |
| 500.12 | MFA implemented for all required scenarios; exceptions CISO-approved and documented             | [ ] |
| 500.15 | Nonpublic Information encrypted at rest and in transit; exceptions documented                   | [ ] |
| 500.16 | Incident Response Plan documented and tested; Notification Event determination process in place | [ ] |
| 500.17 | 72-hour notification process implemented; annual certification filed                            | [ ] |

## 9. Part 500 Gap Assessment: Key Questions by Section

Use the following questions to conduct a preliminary self-assessment of your Part 500 compliance posture before beginning formal remediation planning.

| Section | Self-Assessment Question                                                                                                                                                                | Gap Indicator                                                                                    |
|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
| 500.3   | Has the cybersecurity policy been approved in writing by the Senior Governing Body or Senior Officer within the past 12 months? Does it address all 14 policy areas specified in 500.3? | Unapproved policy; missing policy areas; policy older than 12 months                             |
| 500.4   | Has a qualified CISO been designated and documented? Has the CISO provided a written annual report to the Senior Governing Body?                                                        | No documented CISO designation; no annual written report                                         |
| 500.5   | Has a penetration test been completed in the past 12 months? Have vulnerability assessments been conducted at least bi-annually?                                                        | Last pen test more than 12 months ago; no documented vulnerability assessment schedule           |
| 500.7   | Have access privilege reviews been conducted within the past quarter for privileged accounts? Is there a documented process for periodic access reviews?                                | No documented access review process; reviews not conducted on schedule                           |
| 500.9   | Has a written risk assessment been completed that includes evaluation criteria, CIA assessment criteria, and documented risk acceptance/mitigation requirements?                        | No written risk assessment; existing assessment doesn't meet 500.9(a) documentation requirements |
| 500.11  | Is there a written Third Party Security Policy? Have all Third Party Service Providers with access to Nonpublic Information been inventoried and assessed?                              | No Third Party Security Policy; vendor inventory incomplete or assessments not current           |
| 500.12  | Is MFA implemented for all individuals accessing Information Systems remotely? For all privileged accounts? For third-party applications containing Nonpublic Information?              | MFA gaps in remote access, privileged accounts, or third-party applications                      |
| 500.15  | Is Nonpublic Information encrypted in transit over external networks? At rest? Are any infeasibility determinations documented and CISO-approved?                                       | Encryption gaps; undocumented exceptions                                                         |

|        |                                                                                                                                                                                    |                                                                                    |
|--------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|
| 500.17 | Is there a documented process for determining whether a Cybersecurity Event is a Notification Event? Has the 72-hour notification requirement been communicated to response teams? | No notification determination process; response team unaware of 72-hour obligation |
|--------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|

## 10. Working with Examiners

NYDFS examinations of Part 500 compliance increasingly occur as part of regular safety and soundness or market conduct examinations, rather than as standalone cybersecurity examinations. Understanding what examiners look for can help organizations prepare effectively.

Examiners typically request: the written Cybersecurity Program and Cybersecurity Policy; the most recent Risk Assessment; the annual CISO report to the Senior Governing Body; evidence of penetration testing and vulnerability assessment completion; evidence of annual access reviews; the Third Party Security Policy and a sample of vendor assessments; MFA implementation evidence; and any Notification Event reports filed during the examination period.

Organizations that maintain organized, complete compliance documentation and can demonstrate active program oversight — rather than point-in-time compliance activities — are generally better positioned during examination. A program that 'runs hot' all year (with quarterly Steering Committee meetings, documented risk reviews, and regular training completion tracking) will have little difficulty producing the evidence examiners request.